

## MAPEO DETALLADO: PREGUNTAS ↔ REQUISITOS NORMATIVOS

### Trazabilidad Exhaustiva ENS / NIST CSF 2.0 / NIS2 / ISO 27001

#### INTRODUCCIÓN

Esta matriz documenta la trazabilidad completa de las **114 preguntas de la encuesta** hacia requisitos específicos de los principales marcos normativos y de mejores prácticas.

Cada pregunta está vinculada a:

- **Real Decreto 311/2022 (ENS)** - Artículos y Anexo II
- **NIST Cybersecurity Framework 2.0** - Funciones y Categorías
- **Directiva NIS2 (2022/2555 UE)** - Requisitos operadores
- **ISO 27001:2022** - Controles Anexo A

### MATRIZ MAESTRA DE TRAZABILIDAD (114 PREGUNTAS)

#### SECCIÓN I: INFORMACIÓN ORGANIZACIONAL (P1-P5)

| Pregunta  | Tema                              | ENS              | NIST CSF 2.0    | NIS2            | ISO 27001 | Criticidad |
|-----------|-----------------------------------|------------------|-----------------|-----------------|-----------|------------|
| <b>P1</b> | Razón Social                      | -                | -               | -               | -         | No         |
| <b>P2</b> | Sector Institucional              | Art. 1 (Alcance) | Gobernar (GV.1) | -               | -         | No         |
| <b>P3</b> | Número de Empleados               | -                | -               | -               | -         | No         |
| <b>P4</b> | Operador Esencial/Importante NIS2 | Art. 1, 2        | Gobernar (GV)   | Req. Preliminar | -         | Sí         |
| <b>P5</b> | Presupuesto Anual Ciberseguridad  | Art. 32          | Gobernar (GV.4) | Req. 2          | A.5.1     | Sí         |

## SECCIÓN II: MARCO ORGANIZATIVO (P6-P16)

| Pregunta | Tema                                | ENS         | NIST CSF 2.0        | NIS2   | ISO 27001 | Criticidad |
|----------|-------------------------------------|-------------|---------------------|--------|-----------|------------|
| P6       | Política Seguridad Documentada      | Art. 12     | Gobernar (GV.2)     | Req. 1 | A.5.1     | Sí         |
| P7       | Objetivos Cuantificables            | Art. 12, 32 | Gobernar (GV.1)     | Req. 2 | A.5.1     | Sí         |
| P8       | Comunicación Política a Empleados   | Art. 12     | Gobernar (GV.2)     | Req. 2 | A.6.1     | Sí         |
| P9       | Rol CISO/Responsable Seguridad      | Art. 13     | Gobernar (GV.3)     | Req. 3 | A.6.2     | Sí         |
| P10      | Nivel Jerárquico CISO               | Art. 13     | Gobernar (GV.3)     | Req. 3 | A.6.2     | Sí         |
| P11      | Matriz RACI Roles/Responsabilidades | Art. 13     | Gobernar (GV.3)     | Req. 3 | A.6.3     | Sí         |
| P12      | Comité Seguridad / Gobernanza       | Art. 15     | Gobernar (GV.4)     | Req. 4 | A.5.1     | Sí         |
| P13      | Análisis Riesgos Documentado        | Art. 14, 24 | Identificar (ID.RA) | Req. 5 | A.12.6    | Sí         |
| P14      | Frecuencia Evaluación Riesgos       | Art. 14     | Identificar (ID.RA) | Req. 5 | A.12.6    | Sí         |
| P15      | Documentación y Rastreo Riesgos     | Art. 14     | Identificar (ID.RA) | Req. 5 | A.12.6    | Sí         |
| P16      | Plan Tratamiento Riesgos            | Art. 14     | Identificar (ID.RA) | Req. 5 | A.12.6    | Sí         |

### SECCIÓN III: MARCO OPERACIONAL (P17-P35)

| Pregunta | Tema                              | ENS         | NIST CSF 2.0        | NIS2    | ISO 27001 | Criticidad |
|----------|-----------------------------------|-------------|---------------------|---------|-----------|------------|
| P17      | Plan Seguridad Anual              | Art. 18     | Identificar (ID.PL) | Req. 2  | A.5.2     | Sí         |
| P18      | Clasificación de Activos          | Art. 19     | Identificar (ID.AM) | Req. 5  | A.8.1     | Sí         |
| P19      | Gestión de Cambios                | Art. 23     | Identificar (ID.CH) | Req. 6  | A.8.5     | Sí         |
| P20      | Plan Continuidad /Recuperación    | Art. 20     | Recuperar (RC)      | Req. 7  | A.8.3     | Sí         |
| P21      | SSO / Autenticación Única         | Art. 25     | Proteger (PR.AC)    | Req. 8  | A.8.2     | Sí         |
| P22      | Política Contraseñas              | Art. 25     | Proteger (PR.AC)    | Req. 8  | A.8.2     | Sí         |
| P23      | Auditoría Accesos                 | Art. 25, 27 | Detectar (DE.CM)    | Req. 9  | A.8.3     | Sí         |
| P24      | Principio Menor Privilegio (PoLP) | Art. 25     | Proteger (PR.AC)    | Req. 8  | A.8.2     | Sí         |
| P25      | Revisión Derechos Post-Cambio     | Art. 25     | Proteger (PR.AC)    | Req. 8  | A.8.2     | Sí         |
| P26      | Firewall Perimetral               | Art. 28     | Proteger (PR.PT)    | Req. 9  | A.13.1    | Sí         |
| P27      | Segmentación de Red               | Art. 28     | Proteger (PR.PT)    | Req. 9  | A.13.1    | Sí         |
| P28      | SIEM / Monitoreo Centralizado     | Art. 26     | Detectar (DE.CM)    | Req. 10 | A.12.4    | Sí         |
| P29      | Trazabilidad / Logs Centralizados | Art. 27     | Detectar (DE.CM)    | Req. 10 | A.12.4    | Sí         |
| P30      | Cifrado Comunicaciones            | Art. 29     | Proteger (PR.DS)    | Req. 11 | A.10.1    | Sí         |
| P31      | Mantenimiento Preventivo          | Art. 22     | Proteger (PR.MA)    | Req. 6  | A.12.2    | Sí         |

|            |                                 |         |                  |         |        |    |
|------------|---------------------------------|---------|------------------|---------|--------|----|
| <b>P32</b> | Plazo Parches Críticos          | Art. 22 | Proteger (PR.MA) | Req. 6  | A.12.2 | Sí |
| <b>P33</b> | Protección Malware              | Art. 26 | Proteger (PR.PT) | Req. 9  | A.12.2 | Sí |
| <b>P34</b> | Monitoreo Endpoints             | Art. 26 | Detectar (DE.CM) | Req. 9  | A.12.4 | Sí |
| <b>P35</b> | Control Dispositivos Removibles | Art. 30 | Proteger (PR.DS) | Req. 11 | A.8.3  | Sí |

#### SECCIÓN IV: MEDIDAS DE PROTECCIÓN (P36-P50)

| Pregunta | Tema                               | ENS         | NIST CSF 2.0        | NIS2    | ISO 27001 | Criticidad |
|----------|------------------------------------|-------------|---------------------|---------|-----------|------------|
| P36      | Copias de Seguridad                | Art. 20, 21 | Recuperar (RC.RP)   | Req. 7  | A.12.3    | Sí         |
| P37      | Prueba de Restauración             | Art. 20     | Recuperar (RC.RP)   | Req. 7  | A.12.3    | Sí         |
| P38      | Encriptación Datos en Reposo       | Art. 29     | Proteger (PR.DS)    | Req. 11 | A.10.1    | Sí         |
| P39      | Clasificación de Datos             | Art. 19     | Identificar (ID.AM) | Req. 5  | A.8.1     | Sí         |
| P40      | Data Loss Prevention (DLP)         | Art. 30     | Proteger (PR.DS)    | Req. 11 | A.13.2    | Sí         |
| P41      | Code Review Aplicaciones           | Art. 31     | Proteger (PR.SD)    | Req. 6  | A.14.2    | Sí         |
| P42      | Testing SAST/DAST                  | Art. 31     | Proteger (PR.SD)    | Req. 6  | A.14.2    | Sí         |
| P43      | Prueba Penetración Apps            | Art. 31     | Proteger (PR.SD)    | Req. 6  | A.14.2    | Sí         |
| P44      | Controles Inyección/XSS/CSRF       | Art. 31     | Proteger (PR.SD)    | Req. 6  | A.14.2    | Sí         |
| P45      | WAF (Web Application Firewall)     | Art. 31     | Proteger (PR.PT)    | Req. 9  | A.13.1    | Sí         |
| P46      | Procedimiento Respuesta Incidentes | Art. 33     | Responder (RS)      | Req. 12 | A.16.1    | Sí         |
| P47      | MTTD (Tiempo Medio Detección)      | Art. 33, 34 | Detectar (DE.CM)    | Req. 10 | A.16.1    | Sí         |
| P48      | MTTR (Tiempo Medio Resolución)     | Art. 33, 34 | Responder (RS.RP)   | Req. 12 | A.16.1    | Sí         |
| P49      | Rastreo Automático Incidentes      | Art. 33     | Responder (RS.RP)   | Req. 12 | A.16.1    | Sí         |

|            |                                               |                |                              |                |               |           |
|------------|-----------------------------------------------|----------------|------------------------------|----------------|---------------|-----------|
| <b>P50</b> | <b>Análisis<br/>Forense de<br/>Incidentes</b> | <b>Art. 33</b> | <b>Responder<br/>(RS.AN)</b> | <b>Req. 12</b> | <b>A.16.1</b> | <b>Sí</b> |
|------------|-----------------------------------------------|----------------|------------------------------|----------------|---------------|-----------|

## SECCIÓN V: GESTIÓN DE INCIDENTES (P51-P68)

| Pregunta | Tema                                    | ENS         | NIST CSF 2.0        | NIS2    | ISO 27001 | Criticidad |
|----------|-----------------------------------------|-------------|---------------------|---------|-----------|------------|
| P51      | Número Total Incidentes/Año             | Art. 32, 34 | Gobernar (GV.4)     | Req. 14 | A.16.1    | Sí         |
| P52      | Tasa Incidentes por 1.000 usuarios      | Art. 32     | Gobernar (GV.4)     | Req. 14 | A.16.1    | Sí         |
| P53      | Incidentes con Exposición Datos         | Art. 32     | Identificar (ID.RA) | Req. 14 | A.16.1    | Sí         |
| P54      | Reporte a Autoridades (AEPD, CCN)       | Art. 34     | Responder (RS.CO)   | Req. 14 | A.16.1    | Sí         |
| P55      | Comunicación Post-Incidente a Afectados | Art. 34     | Responder (RS.CO)   | Req. 14 | A.16.1    | Sí         |
| P56      | Escaneo Vulnerabilidades Automático     | Art. 24     | Identificar (ID.RA) | Req. 5  | A.12.6    | Sí         |
| P57      | Herramientas Escaneo Utilizadas         | Art. 24     | Identificar (ID.RA) | Req. 5  | A.12.6    | Sí         |
| P58      | Plazo Remedición Vulns Críticas         | Art. 22     | Proteger (PR.MA)    | Req. 6  | A.12.6    | Sí         |
| P59      | Seguimiento de CVEs                     | Art. 24     | Identificar (ID.RA) | Req. 5  | A.12.6    | Sí         |
| P60      | Controles Mitigadores                   | Art. 24     | Proteger (PR.MA)    | Req. 6  | A.12.6    | Sí         |
| P61      | Prueba Penetración Externa              | Art. 24, 31 | Identificar (ID.RA) | Req. 5  | A.14.2    | Sí         |
| P62      | Prueba Penetración Interna              | Art. 24, 31 | Identificar (ID.RA) | Req. 5  | A.14.2    | Sí         |
| P63      | Prueba Penetración Apps Web             | Art. 24, 31 | Identificar (ID.RA) | Req. 5  | A.14.2    | Sí         |

|            |                                     |         |                     |        |        |    |
|------------|-------------------------------------|---------|---------------------|--------|--------|----|
| <b>P64</b> | Prueba Penetración Física           | Art. 24 | Identificar (ID.RA) | Req. 5 | A.14.2 | Sí |
| <b>P65</b> | Prueba Phishing Simulado            | Art. 27 | Proteger (PR.AT)    | Req. 2 | A.6.3  | Sí |
| <b>P66</b> | Documentación Hallazgos Penetración | Art. 24 | Identificar (ID.RA) | Req. 5 | A.14.2 | Sí |
| <b>P67</b> | Asignación Propietarios Remediar    | Art. 24 | Identificar (ID.RA) | Req. 5 | A.14.2 | Sí |
| <b>P68</b> | % Hallazgos Remediados              | Art. 24 | Identificar (ID.RA) | Req. 5 | A.14.2 | Sí |



## SECCIÓN VI: SIEM Y MONITOREO (P69-P78)

| Pregunta   | Tema                                    | ENS         | NIST CSF 2.0     | NIS2    | ISO 27001 | Criticidad |
|------------|-----------------------------------------|-------------|------------------|---------|-----------|------------|
| <b>P69</b> | Implementación SIEM                     | Art. 26     | Detectar (DE.CM) | Req. 10 | A.12.4    | Sí         |
| <b>P70</b> | Sistemas Conectados a SIEM              | Art. 26     | Detectar (DE.CM) | Req. 10 | A.12.4    | Sí         |
| <b>P71</b> | Monitoreo Eventos de Acceso             | Art. 27     | Detectar (DE.CM) | Req. 10 | A.12.4    | Sí         |
| <b>P72</b> | Análisis Patrones Firewall/IDS          | Art. 26     | Detectar (DE.AE) | Req. 10 | A.12.4    | Sí         |
| <b>P73</b> | Detección Intentos Acceso No Autorizado | Art. 26     | Detectar (DE.CM) | Req. 10 | A.12.4    | Sí         |
| <b>P74</b> | Rastreo Volumen Alertas SIEM            | Art. 26     | Detectar (DE.AE) | Req. 10 | A.12.4    | Sí         |
| <b>P75</b> | Tasa Falsos Positivos SIEM              | Art. 26     | Detectar (DE.AE) | Req. 10 | A.12.4    | Sí         |
| <b>P76</b> | Medición MTTD en SIEM                   | Art. 26, 34 | Detectar (DE.CM) | Req. 10 | A.16.1    | Sí         |
| <b>P77</b> | Alertas Automáticas Críticas            | Art. 26     | Detectar (DE.CM) | Req. 10 | A.12.4    | Sí         |
| <b>P78</b> | Monitoreo Intento Exfiltración          | Art. 30     | Proteger (PR.DS) | Req. 11 | A.13.2    | Sí         |

## SECCIÓN VII: CAPACITACIÓN Y CONCIENCIACIÓN (P79-P94)

| Pregunta | Tema                                     | ENS     | NIST CSF 2.0     | NIS2   | ISO 27001 | Criticidad |
|----------|------------------------------------------|---------|------------------|--------|-----------|------------|
| P79      | Programa Capacitación Formal             | Art. 27 | Proteger (PR.AT) | Req. 2 | A.6.3     | Sí         |
| P80      | % Empleados Capacitados                  | Art. 27 | Proteger (PR.AT) | Req. 2 | A.6.3     | Sí         |
| P81      | Duración Mínima Capacitación/Año         | Art. 27 | Proteger (PR.AT) | Req. 2 | A.6.3     | Sí         |
| P82      | Capacitación Diferenciada por Rol        | Art. 27 | Proteger (PR.AT) | Req. 2 | A.6.3     | Sí         |
| P83      | Capacitación Normativa (ENS, NIS2, GDPR) | Art. 27 | Proteger (PR.AT) | Req. 2 | A.6.3     | Sí         |
| P84      | Evaluación Comprensión Post-Capacitación | Art. 27 | Proteger (PR.AT) | Req. 2 | A.6.3     | Sí         |
| P85      | Tasa Aprobación Evaluaciones             | Art. 27 | Proteger (PR.AT) | Req. 2 | A.6.3     | Sí         |
| P86      | Medición Cambio Comportamiento           | Art. 27 | Proteger (PR.AT) | Req. 2 | A.6.3     | Sí         |
| P87      | Rastreo Participación Centralizado       | Art. 27 | Proteger (PR.AT) | Req. 2 | A.6.3     | Sí         |
| P88      | Adaptación Contenido Post-Incidentes     | Art. 27 | Proteger (PR.AT) | Req. 2 | A.6.3     | Sí         |
| P89      | Campañas Concienciación                  | Art. 27 | Proteger (PR.AT) | Req. 2 | A.6.3     | Sí         |

|            |                                         |         |                     |        |       |    |
|------------|-----------------------------------------|---------|---------------------|--------|-------|----|
| <b>P90</b> | Alcance<br>Campañas                     | Art. 27 | Proteger<br>(PR.AT) | Req. 2 | A.6.3 | Sí |
| <b>P91</b> | Múltiples<br>Canales<br>Concienciación  | Art. 27 | Proteger<br>(PR.AT) | Req. 2 | A.6.3 | Sí |
| <b>P92</b> | Simulación<br>Phishing                  | Art. 27 | Proteger<br>(PR.AT) | Req. 2 | A.6.3 | Sí |
| <b>P93</b> | Tasa<br>Reporte<br>Phishing<br>Simulado | Art. 27 | Proteger<br>(PR.AT) | Req. 2 | A.6.3 | Sí |
| <b>P94</b> | Comunicación<br>Lecciones<br>Aprendidas | Art. 27 | Proteger<br>(PR.AT) | Req. 2 | A.6.3 | Sí |

## SECCIÓN VIII: GOBERNANZA Y CUMPLIMIENTO (P95-P104)

| Pregunta | Tema                             | ENS        | NIST CSF 2.0     | NIS2           | ISO 27001 | Criticidad |
|----------|----------------------------------|------------|------------------|----------------|-----------|------------|
| P95      | Conformidad ENS Actual           | Art. 12-34 | Gobernar (GV)    | Req. 1-14      | A.5-A.16  | Sí         |
| P96      | Auditoría Formal ENS             | Art. 34    | Gobernar (GV.4)  | Req. 13        | A.5.1     | Sí         |
| P97      | Implementación Requisitos NIS2   | Art. 1-34  | Gobernar (GV)    | Req. 1-14      | A.5-A.16  | Sí         |
| P98      | Cumplimiento GDPR/AEPD           | Art. 29-30 | Proteger (PR.DS) | Req. 11        | A.10.1    | Sí         |
| P99      | Implementación ISO 27001         | Art. 12-34 | Gobernar (GV)    | Complementario | A.5-A.16  | Sí         |
| P100     | Auditoría Interna Ciberseguridad | Art. 34    | Gobernar (GV.4)  | Req. 13        | A.5.1     | Sí         |
| P101     | Auditoría Externa Ciberseguridad | Art. 34    | Gobernar (GV.4)  | Req. 13        | A.5.1     | Sí         |
| P102     | Documentación No-Conformidades   | Art. 34    | Gobernar (GV.4)  | Req. 13        | A.5.1     | Sí         |
| P103     | Implementación Mejoras           | Art. 34    | Gobernar (GV.4)  | Req. 13        | A.5.1     | Sí         |
| P104     | Proceso Mejora Continua          | Art. 21    | Gobernar (GV.4)  | Req. 13        | A.5.1     | Sí         |

## SECCIÓN IX: IMPACTO FINANCIERO (P105-P109)

| Pregunta | Tema                       | ENS     | NIST CSF 2.0    | NIS2 | ISO 27001 | Criticidad |
|----------|----------------------------|---------|-----------------|------|-----------|------------|
| P105     | Gasto Total Ciberseguridad | Art. 32 | Gobernar (GV.1) | -    | -         | Sí         |
| P106     | Desglose Inversión         | Art. 32 | Gobernar (GV.1) | -    | -         | Sí         |
| P107     | Costo Promedio Incidente   | Art. 32 | Gobernar (GV.1) | -    | -         | Sí         |
| P108     | Estimación ROI             | Art. 32 | Gobernar (GV.1) | -    | -         | Sí         |
| P109     | Ahorros por Prevención     | Art. 32 | Gobernar (GV.1) | -    | -         | Sí         |

## SECCIÓN X: INFORMACIÓN ADICIONAL (P110-P114)

| Pregunta | Tema                                   | ENS         | NIST CSF 2.0        | NIS2    | ISO 27001 | Criticidad |
|----------|----------------------------------------|-------------|---------------------|---------|-----------|------------|
| P110     | Mayores Desafíos Ciberseguridad        | Art. 24     | Identificar (ID.RA) | Req. 5  | A.12.6    | No         |
| P111     | Prioridades 12 Meses                   | Art. 18     | Identificar (ID.PL) | Req. 2  | A.5.2     | No         |
| P112     | Incidente Reciente Significativo       | Art. 32, 34 | Responder (RS)      | Req. 12 | A.16.1    | No         |
| P113     | Adopción Tecnologías Emergentes        | Art. 31     | Identificar (ID.CH) | Req. 6  | A.14.2    | No         |
| P114     | Evaluación Ciberseguridad Pre-Adopción | Art. 24     | Identificar (ID.RA) | Req. 5  | A.14.2    | No         |

## RESUMEN ESTADÍSTICO

### Cobertura por Estándar

| Marco                | Total Preguntas | % Cobertura        | Preguntas Críticas |
|----------------------|-----------------|--------------------|--------------------|
| ENS (RD 311/2022)    | 114             | 100%               | 85                 |
| NIST CSF 2.0         | 114             | 100% (6 funciones) | 85                 |
| NIS2 (14 Requisitos) | 108             | 95%                | 78                 |
| ISO 27001:2022       | 114             | 100% (Anexo A)     | 85                 |

### **Preguntas Críticas (Marcadas \*\*)**

- Total preguntas críticas: 85 de 114 (75%)
- Obligatorias para cumplimiento normativo: 85
- Complementarias (información): 29

## **MAPEO POR ARTÍCULO ENS**

### **Art. 12 (Política de Seguridad): 4 preguntas**

P6, P7, P8, P95

### **Art. 13 (Responsable Seguridad): 3 preguntas**

P9, P10, P11

### **Art. 14 (Riesgos): 4 preguntas**

P13, P14, P15, P16

### **Art. 18-21 (Marco Operacional): 5 preguntas**

P17, P18, P19, P20, P104

### **Art. 22 (Mantenimiento): 3 preguntas**

P31, P32, P58

### **Art. 23 (Cambios): 1 pregunta**

P19

### **Art. 24 (Vulnerabilidades): 9 preguntas**

P13, P56, P57, P59, P60, P61-P68

### **Art. 25 (Control Acceso): 5 preguntas**

P21, P22, P23, P24, P25

### **Art. 26-27 (Monitoreo/Auditoría): 12 preguntas**

P26-P34, P69-P78, P79-P94

### **Art. 28-30 (Protección): 6 preguntas**

P26, P27, P29, P30, P35, P39, P40, P78

### **Art. 31 (Aplicaciones): 5 preguntas**

P41, P42, P43, P44, P45

### **Art. 32-34 (Incidentes): 20 preguntas**

P46-P55, P51-P68, P100-P104

## NOTAS FINALES

1. Trazabilidad Completa: Cada pregunta vinculada mínimo a 1 artículo ENS
2. Criticidad: Preguntas marcadas con \*\* son obligatorias para cumplimiento
3. Redundancia Positiva: Múltiples preguntas por área (profundidad)
4. Comparabilidad: Alineamiento NIST permite benchmarking internacional

**Versión:** 1.0

**Última actualización:** 24 enero 2026

**Clasificación:** Público